Acme Global Cloud Security & Compliance Policy

Document Ref: SEC-2026-v4.2 | Classification: Confidential Enterprise Standard | Effective Date: Jan 2026

1. Executive Summary & Purpose

This policy governs cybersecurity operations, cryptographic safeguards, and access controls for all Acme Corporation cloud infrastructure, microservices, and client data repositories. All employees, engineering teams, and third-party contractors are legally obligated to follow the mandates outlined in this document.

2. Zero Trust Identity & Access Management (IAM)

Acme mandates a strict Zero Trust architecture across all corporate environments. No device or user is inherently trusted regardless of network perimeter location.

- **Hardware MFA Requirement:** All access to production servers, databases, and CI/CD pipelines requires FIDO2/WebAuthn hardware security keys. SMS authentication is strictly prohibited.
- **Least Privilege Enforcement:** IAM roles must be scoped to the minimal required IAM policies with automatic 4-hour privilege expiry.
- **Session Timeout:** Corporate SSH and web console sessions automatically terminate after 15 minutes of inactivity.

3. Data Encryption & Cryptographic Standards

Customer proprietary data and internal intellectual property must be protected in all lifecycle states.

- **Encryption at Rest:** All databases, vector embeddings, and object storage volumes must be encrypted with AES-256 via customer-managed keys (CMEK) rotated every 90 days.
- **Encryption in Transit:** TLS 1.3 is strictly enforced for all public API endpoints and internal RPC traffic. TLS 1.0, 1.1, and 1.2 are formally deprecated and blocked at the edge proxy.

4. Incident Response Timelines & SLAs

In the event of a suspected security intrusion or data leakage event, Acme adheres to strict response SLAs:

Severity Level	Definition	Containment SLA	Executive Notification
P0 - Critical	Unauthorized data exfiltration or active ransomware	15 minutes	30 minutes
P1 - High	Compromised credential with elevated permissions	1 hour	2 hours
P2 - Medium	Policy violation without data exposure	4 hours	24 hours
P3 - Low	Benign vulnerability scan or minor anomaly	24 hours	Weekly digest

5. Backup, Disaster Recovery & Retention

- **Recovery Point Objective (RPO):** Less than 15 minutes across multi-region vector caches and transactional databases.
- **Recovery Time Objective (RTO):** Full failover recovery executed under 2 hours.
- **Compliance Log Retention:** Immutable security audit trails, access logs, and query histories must be archived for a mandatory minimum of 7 years in WORM-compliant storage.